

# Security issues in virtual machine

Prof. Hyung-Jong(JOHN) Kim  
*hkim@swu.ac.kr*

Dept. of Information Security  
Seoul Women's University



# Agenda

- 11 Risks of Virtual Environment
  - VM itself
  - Virtual Network
  - Hypervisor
  - Management Problem



# 1 1 Risks in Virtual Environment

- Risk 1 – VM Sprawl
  - Uncontrolled proliferation of VMs can lead to an unmanageable condition of unpatched and unaccounted-for machines.
- Risk 2 – Sensitive Data Within a VM
  - Data confidentiality within VMs can be easily compromised, because data can be easily transported and tampered with.
- Risk 3 – Security of Offline and Dormant VMs
  - Dormant and offline VMs can eventually deviate so far from a current security baseline that simply powering them on introduces massive security vulnerabilities.

# 1 1 Risks in Virtual Environment

- Risk 4 – Security of Pre-Configured (Golden Image) VM / Active VMs
  - VMs exist as files on a virtualization platform, which can lead to unauthorized access, resulting in machine configuration changes or viral payload injection into the platform's virtual disks.
- Risk 5 – Lack of Visibility Into and Control Over Virtual Networks
  - Software-defined virtual networks can cause network security breaches, because traffic over virtual networks may not be visible to security protection devices on the physical network.
- Risk 6 – Resource Exhaustion
  - Uncontrolled physical resource consumption by virtual processes can lead to reduced availability.

# 1 1 Risks in Virtual Environment

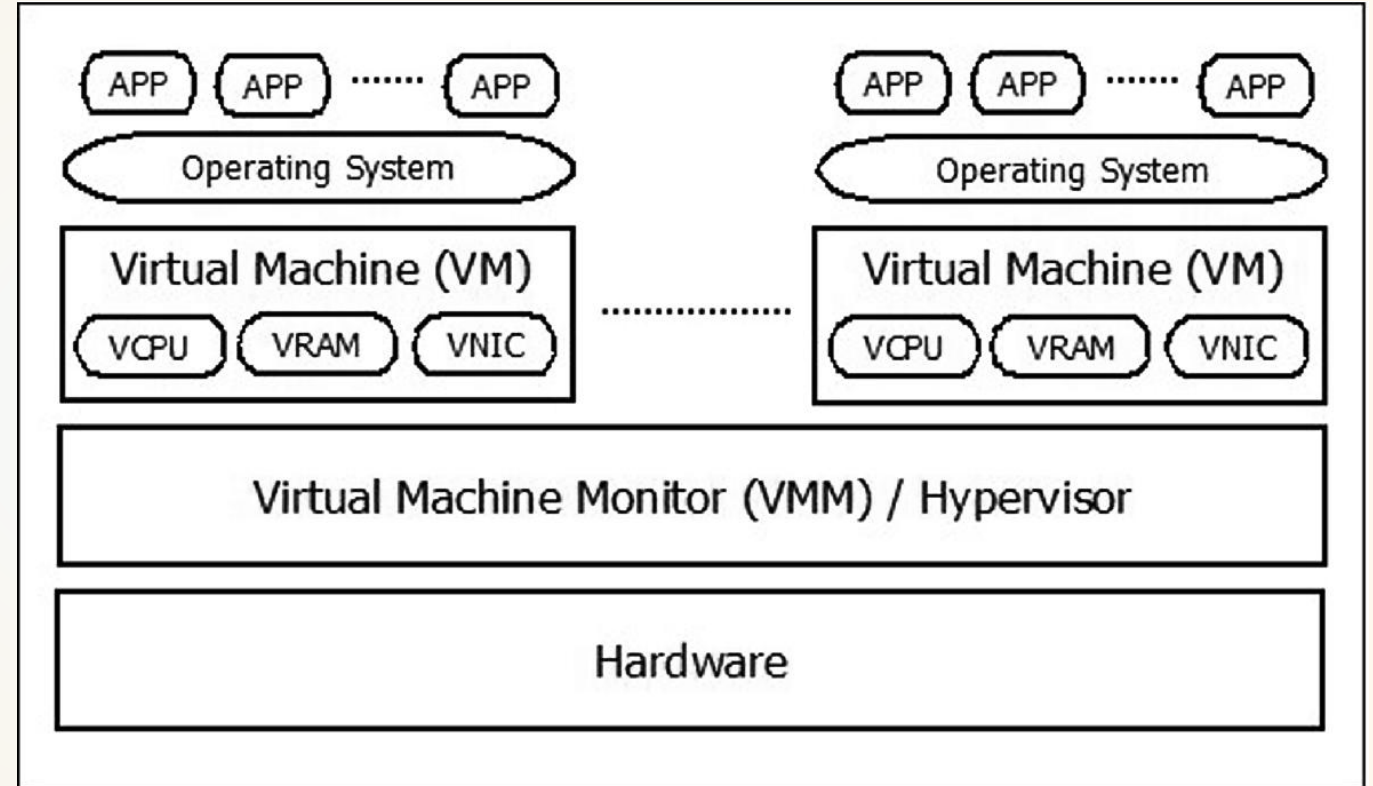
- Risk 7 – Hypervisor Security
  - Hypervisor security is the process of ensuring that the hypervisor, the software that enables virtualization, is secure throughout its life cycle, including development, implementation, provisioning, and management.
- Risk 8 – Unauthorized Access to Hypervisor
  - Administrative access controls to the hypervisor may not be adequate to protect against potential hacker attacks.
- Risk 9 – Account or Service Hijacking Through the Self-Service Portal
  - Portal vulnerabilities can lead to privilege escalation attacks.

# 1 1 Risks in Virtual Environment

- Risk 10 – Workloads of Different Trust Levels Located on the Same Server
  - Ensure that there is sufficient security segregation of workloads on a physical host
- Risk 11 – Risk Due to Cloud Service Provider APIs
  - A hybrid (private / public) cloud virtualization implementation can pose security risks due to account / authentication federation.

## 9 out of 11 Risks

- VM itself
- Virtual Network
- Hypervisor
- Management Problem





# Risk #1 - VM Sprawl

- **Vulnerability**

- VMs can be allocated quickly using the image files.
- The VMs which are introduced using image files may not be visible to system manager.
- More importantly, the system manager cannot recognize the vulnerabilities of the VMs.
  - Normally the system manager should be able to recognize the procuring and bringing physical machines.

- **Countermeasures**

- Effective policies, guidelines and processes for governing and controlling the introducing process of the VMs.
- Technical tools are required for supporting the policies, guidelines and processes.



## Risk #2 - Sensitive Data Within a VM

- **Vulnerability**

- The sensitive data includes passwords, personal data, bash profiles, bash history files, encryption keys, and license keys.
- A snapshot of VM should include the memory contents, it could be a potential channel of revealing the sensitive data.

- **Countermeasures**

- When an image is created, a discreet procedure for preventing from inclusion of sensitive data should be defined.
- In this reason, we can consider encryption of the sensitive data when an image and snapshot is created.

# Risk #3 - Security of Offline and Dormant VMs

- **Vulnerability**

- VMs has three states such as active(running), dormant(suspended) and offline (shut down).
- While the VMs are the dormant and offline states, there are possibility of not being updated with proper security patches and updates.
- When those VMs which are not updated properly come online, the VMs could be in a vulnerable state.

- **Countermeasures**

- The effective policies, guidelines, and processes are required to prevent those offline and dormant VMs from coming online without proper security management such as installing security updates and applying security configuration.
- Management solutions which have the functionality of installing security updates and applying security configuration for the offline and dormant VMs.

# Risk #4 - Security of Pre-Configured (Golden Image) VM / Active VMs

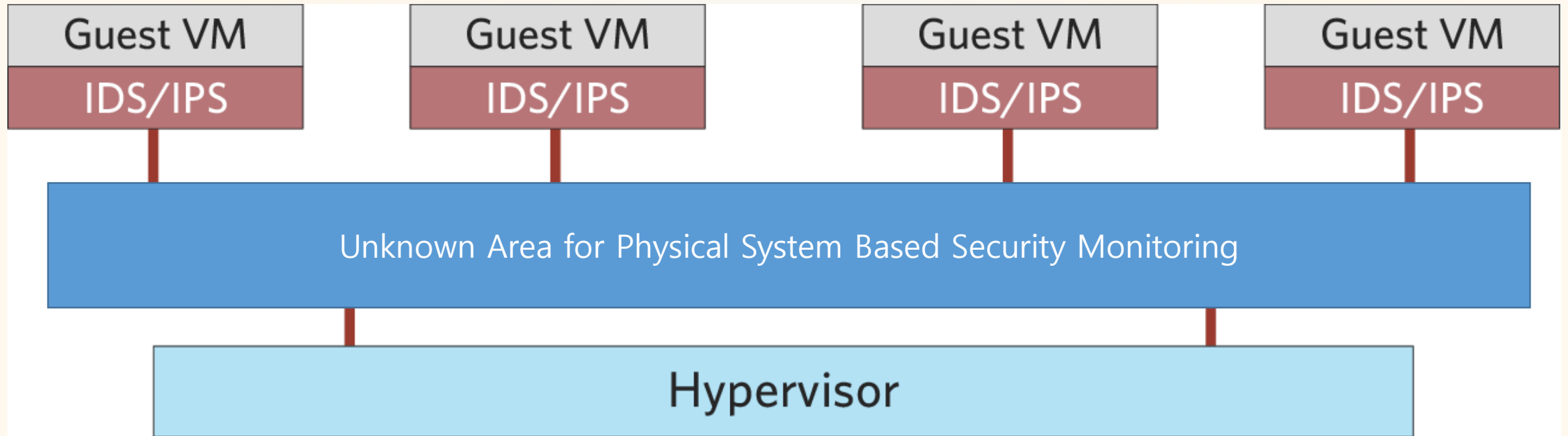
- **Vulnerability**

- Because the VMs images exist as files, while they are transferred through the internet or a USB memory stick
- There is a chance of malicious interception for compromising those VM images.
- If there is a golden VM images which are widely used in a certain environment or a period of time, the area of getting damage would be larger.

- **Countermeasures**

- Implement an integrity checksum mechanism for all VM images.
- Encryption of VM images could be a effective security countermeasures.

## Risk #5 - Lack of Visibility Into and Control Over Virtual Networks



# Risk #5 - Lack of Visibility Into and Control Over Virtual Networks

- **Vulnerability**

- It is not usual for engineers to figure out the security policies on the virtual networks.
  - Engineers need to study more to deploy the security countermeasure on the software-based virtual networks.
- The traffic monitoring tools cannot recognize the traffic on the channel of VMs-to-VMs.

- **Countermeasures**

- Security managers need to survey a specialized tools for monitoring the traffic among virtual machines
- Deploy the technical tool in a unified way with the tools for physical systems.

# Risk #6 - Resource Exhaustion

- **Vulnerability**

- If a certain application is running in many VMs at the same time, it can cause performance degradation in a certain physical system.
- The anti-virus software running and automated operating system patches can create an enormous strain on a physical resource.

- **Countermeasures**

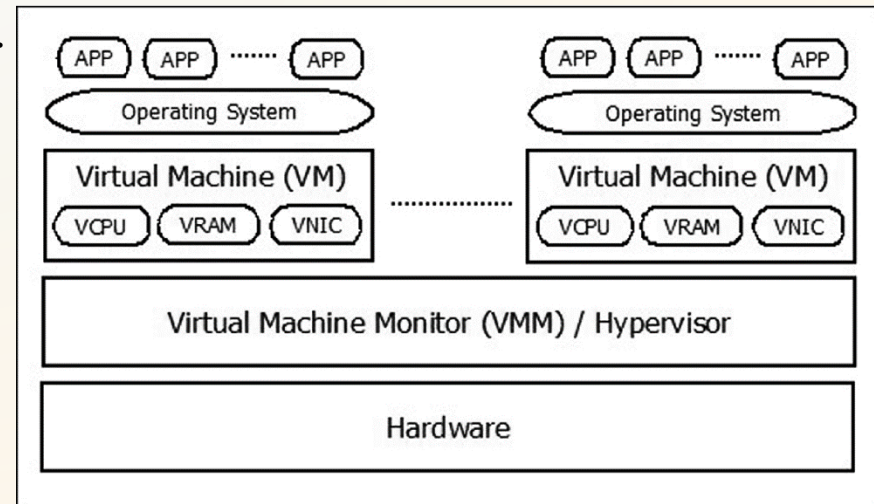
- Using resource-intensive software should be controlled on virtual machine environment
- A standard operation procedure for running the resource-intensive software.

## Risk #7 - Hypervisor Security

## Risk #8 - Unauthorized Access to Hypervisor

### • Vulnerability

- Hackers can aim at the hypervisor to succeed in gaining unauthorized access to the VMs.
  - The way of accessing the hypervisors is various and depends on the hypervisor.
  - Controlling access to the hypervisor is a specialized expertise of an engineer who are good at managing a certain hypervisor of a vendor.
- There is a malware named "hyper-jacking" that penetrates one VM first and it attacks the hypervisor using the VM as stepping stone.





## Risk #7 - Hypervisor Security

## Risk #8 - Unauthorized Access to Hypervisor

- **Countermeasures**

- Follow the vendor provided best practices.
  - The best practice includes all kinds of configuration for securing hypervisors such as disabling memory sharing between VMs, conducting self-integrity checks upon boot-up and so on.
- When it comes to choosing secure hypervisor type, Type 1 hypervisor is recommended rather than Type 2.
- Regarding management of the access to the hypervisor, we had better deploy role-based access control with well defined policies and sufficient test of the policies.

# Risk #10 - Workloads of Different Trust Levels Located on the Same Server

- **Vulnerability**

- One of the VM on a physical system deals with a mission-critical workload
  - The other VMs on the same physical system deal with less-critical workload
- there could be unexpected leakage of data through side-channel or denial of service in the mission-critical VM.

- **Countermeasures**

- Implement policies to categorize workloads according to different security classifications.
- The workloads of different security level should be allocated in different physical systems and different physical and virtual networks.
- Security manager needs to define security zones based on usage type and production stage.
- A security zone would include a bunch of VMs and the workloads would be allocated to the VMs by matching the workload security classification with security zone's purpose.